ZERO-TRUST-SUPPLY-CHAIN-N2SF

제로 트러스트·공급망 보안·N2SF

연관 기출 · 131-2-4, 135-4-6, 136-4-4, 137-3-6

한눈에 이해

내부망·기존 계정·납품업체라는 이유만으로 접근을 허용하지 않고 자원별 정책과 관측 증거로 판단합니다.

정의와 핵심 원리

제로 트러스트는 위치나 자산 소유만으로 암묵적 신뢰를 주지 않고 각 접근의 인증·인가·상태를 평가하는 보안 원칙입니다. 공급망 보안은 개발·빌드·의존성·배포·운영의 신뢰를 관리하며 N2SF는 국가·공공기관의 정보 중요도와 위협 기반 망 보안 체계를 지향합니다.

• NIST SP 800-207의 정책 엔진은 접근을 결정하고, 정책 관리자는 통신 경로를 설정하거나 해제합니다. 정책 집행 지점(PEP)은 연결을 허용·감시·종료합니다. 모든 통신 보호, 세션별 최소 권한, 동적 정책과 자산 상태 관찰을 함께 적용합니다.

• 공급망 보안은 소스 보호, 동료 검토, 의존성 고정, 취약점·라이선스 분석, 격리 빌드, 서명과 출처 기록, SBOM, 배포 검증과 운영 감시를 포함합니다. 빌드에 쓰는 비인간 신원(NHI)과 토큰은 수명을 짧게 하고 최소 권한을 줍니다. 외부 공급자의 접근 범위는 필요한 서비스로 제한합니다.

• N2SF는 정보와 서비스를 식별하고 C/S/O로 분류해 업무 환경에 맞는 대책을 정하는 방식으로 설명합니다. 2025년 초안, 2025년 9월 정식 1.0과 후속 지침을 구분합니다. CISA 성숙도 모델 2.0의 세부 구성과 N2SF의 상세 통제는 원문 확인이 필요합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
경계 보안	망 위치 중심 기본 정책	경계 통제는 여전히 활용 가능
제로 트러스트	자원·신원·상태·세션	점진 이행·관측 필요
공급망/N2SF	생애 주기 신뢰/공공 위험 기반	서명·분류만으로 완료 아님

적용 예제

외부 유지보수업체 접근

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 협력사 계정으로 VPN에 접속하면 내부망 전체에 접근할 수 있던 환경입니다.

1. 자산·서비스·신원·데이터 흐름을 식별합니다.
2. 유지보수 대상과 시간, 승인 여부, 접속 단말 상태를 기준으로 접근 정책을 정합니다.
3. 연결 중의 행동과 상태를 관찰하고 위험이 높아지면 세션을 종료합니다.
4. 서명된배포물·작업 기록과 계약 종료 권한 회수를 검증합니다.

결과·해석: 망 경계 하나의 신뢰를 업무 자원별 검증과 수명 관리로 세분합니다.

전제·주의: CISA 2.0은 HTTP 403으로 열람하지 못했고 N2SF 공식 원문은 미열람입니다. 일반 ZT 설계를 해당 제도 세부 요건 충족으로 표시하지 않습니다.

답안 골격과 혼동 방지

원칙 → PE/PA/PEP 도식 → 경계 비교 → 공급망 적용 → N2SF 검증 상태

- ZT 도입을 VPN 제거 제품 하나로 축소하지 않습니다.
- 물리 망 분리와 ZT를 항상 택일이라고 설명하지 않습니다.

내용을 가리고 회상

1. 세션별로 최소 권한을 준다는 것은 무엇입니까?
2. 서명된 배포물이라도 악성코드가 포함될 수 있는 이유는 무엇입니까?
3. N2SF의 정보 등급을 사용자 인가 정책에 어떻게 연결할 수 있습니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- NIST SP800-207: Zero Trust Architecture - Scott Rose et al. / NIST; 2020-08; 확인 2026-11-05.
- Workload identities overview - Microsoft; 상시 문서; 확인 2026-11-05.